

SecureForge Web

Relatório de Postura de Segurança

Gerado em 24/07/2026, 16:48:43

Identificação da aplicação

OWASP Mutillidae II

Stack: PHP + HTML + CSS + JavaScript
Análise: Análise 24/07/2026 — Checklist Essential SecureForge v1.0
Concluída em: 24/07/2026
Gerado por: SecureForge Web (secureforgeweb@gmail.com)

Resumo executivo

38%	15	15	0%
Score de postura	Total de achados	Achados abertos	Taxa de resolução

Achados por severidade

Crítica: 5
Alta: 6
Média: 4

Plano de ação priorizado

AUTH-02 — Hash de senha forte Crítica · Imediata · Aberto · Autenticação Ação recomendada: Adote bcrypt (custo 12+) ou Argon2id para hash de senhas.
INPUT-02 — Queries SQL parametrizadas Crítica · Imediata · Aberto · Validação de entrada Ação recomendada: Use ORM ou prepared statements; nunca concatene SQL com input do usuário.
SECRET-01 — Segredos em variáveis de ambiente Crítica · Imediata · Aberto · Proteção de credenciais Ação recomendada: Use .env (não versionado) ou vault; nunca commite credenciais.
SECRET-02 — Ausência de credenciais no repositório Crítica · Imediata · Aberto · Proteção de credenciais Ação recomendada: Execute varredura de segredos e rotacione credenciais expostas.
DATA-01 — HTTPS/TLS em trânsito Crítica · Imediata · Aberto · Dados sensíveis Ação recomendada: Configure TLS em todos os ambientes acessíveis externamente.
AUTH-01 — Política de senha mínima Alta · Curto prazo · Aberto · Autenticação Ação recomendada: Exigir 8+ caracteres com maiúscula, minúscula, número e especial.

AUTH-03 — Proteção contra força bruta

Alta · Curto prazo · Aberto · Autenticação

Ação recomendada: Implemente rate limit no endpoint de login e bloqueio temporário.

AUTHZ-02 — Princípio do menor privilégio

Alta · Curto prazo · Aberto · Autorização

Ação recomendada: Audite papéis e remova acessos desnecessários.

HEADER-01 — Content-Security-Policy

Alta · Curto prazo · Aberto · Headers de segurança

Ação recomendada: Defina Content-Security-Policy adequada ao tipo de aplicação.

HEADER-02 — Strict-Transport-Security

Alta · Curto prazo · Aberto · Headers de segurança

Ação recomendada: Configure Strict-Transport-Security em produção.

DATA-02 — Dados sensíveis fora de logs

Alta · Curto prazo · Aberto · Dados sensíveis

Ação recomendada: Mascare dados sensíveis antes de registrar em logs.

HEADER-03 — X-Frame-Options / frame-ancestors

Média · Médio prazo · Aberto · Headers de segurança

Ação recomendada: Use X-Frame-Options: DENY ou CSP frame-ancestors.

HEADER-04 — X-Content-Type-Options

Média · Médio prazo · Aberto · Headers de segurança

Ação recomendada: Defina X-Content-Type-Options: nosniff.

EXPOS-02 — Documentação de API restrita

Média · Médio prazo · Aberto · Exposição de endpoints

Ação recomendada: Proteja ou desabilite docs de API em ambiente de produção.

SURF-01 — Portas e serviços desnecessários

Média · Médio prazo · Aberto · Superfície de ataque

Ação recomendada: Desative portas, debug endpoints e serviços não utilizados.

